



Retrospectivas

Qué mejoró el proceso en cada iteración

Proyecto	Revela (ex GeoCRM)	Autor	Yair Hamir Costa Pérez
Código	REV-06	Asignatura	CAPSTONE (APT122) · sección 003D
Versión / fecha	1.0 · 01-10-2026	Institución	Duoc UC · Sede Antonio Varas
Estado	Versión para revisión	Docente	Rocío Contreras

Nota de transparencia

Las retrospectivas de las iteraciones 2 a 4 se redactaron el 01-10-2026 a partir del historial de Git y de los documentos del proyecto. Los hechos y las mejoras son reales y cada mejora se incorporó al proceso o al código, pero no se registraron en una reunión al cierre de cada iteración. La iteración 1 reúne el trabajo previo al primer commit y no tiene retrospectiva propia. La iteración 5 se completa al cerrarla (06-10-2026).

Formato: qué pasó, cuál fue la causa y qué se mejoró; más lo que funcionó bien.

Iteración 2 · 26-09-2026 · Base de datos real

Qué pasó	Causa	Qué mejoró
Las invitaciones de usuarios fallaban al conectar con Supabase	Faltaban permisos de las tablas para la clave de servicio; la revisión local no lo podía ver	Migración 0016 y regla nueva: toda tabla lleva permisos explícitos para authenticated y service_role
Un lead con solicitud del titular (25-09) se podía seguir moviendo	El bloqueo existía solo en pantalla	El bloqueo pasó a los <i>guards</i> y, después, a la base
El lint contra la base encontró un error que la revisión local no veía (la exportación)	Una función con una columna inexistente	Migración 0013 y hábito nuevo: después de aplicar una migración se corre db lint y test:db

Funcionó bien: probar contra la base real descubrió dos errores antes de que llegaran a un usuario.

Iteración 3 · 27-09-2026 · Publicación y seguridad

Qué pasó	Causa	Qué mejoró
La revisión de seguridad de la app publicada encontró hallazgos (B1 a B11); el más grave: el asistente no pedía sesión y cualquiera en internet podía usar las claves del servidor	La API se diseñó primero para el desarrollo local	El asistente exige sesión de un CRM publicado; se agregó la CSP y las reglas por perfil en la base (migración 0022)
El ataque simulado contra la base real tuvo 12 fallas	Reglas solo en la pantalla, no en la base	Las reglas pasaron a la base; la prueba de ataques quedó en test:db y terminó en 0 de 37 fallas

Funcionó bien: revisar la seguridad antes de abrir la app a usuarios reales evitó que el fallo llegara a producción.

Iteración 4 · 30-09-2026 · Asistente con control de costo

Qué pasó	Causa	Qué mejoró
El registro de cambios de la base no anotaba los cambios hechos por el servidor	El trigger ignoraba las escrituras sin sesión de persona	El cambio de presupuesto y de clave pasó por funciones de la base que escriben el registro a nombre de quien lo hizo
Un campo de presupuesto vacío se leía como 0 y habría apagado el asistente sin que nadie lo pidiera	<code>Number('')</code> es 0	Validación corregida y cubierta por una prueba
Una sola clave de OpenAI servía a todas las empresas: la gerencia de cualquiera podía gastar la cuenta de otra	Diseño inicial con clave de la plataforma	Cada empresa trae su clave , cifrada en Vault (migración 0032)
Dudas sobre si las pruebas de seguridad realmente detectaban fallas	Las pruebas nuevas pasaron a la primera	Pruebas de mutación a mano : se rompió a propósito la protección y se comprobó que las pruebas fallaban

Funcionó bien: desconfiar de las pruebas que pasan a la primera y comprobarlas rompiendo el código a propósito.

Iteración 5 · 30-09-2026 · Preparar el repositorio para evaluar (parcial)

Qué pasó	Causa	Qué mejoró
Un escaneo previo a publicar encontró capturas de pantalla con nombres y correos reales de personas de la empresa piloto	Las capturas se generaron con datos del piloto en una versión anterior	Se regeneraron con la demo pública (datos ficticios) y se anonimizó el historial antes de subirlo
La demo pública mostraba nombres de personas reales y el catálogo real de la empresa piloto	Los datos de demostración se construyeron a partir de la empresa con la que se pilotea	Se reemplazaron por datos ficticios, se verificó sobre la app compilada y en producción, y se agregaron a las pruebas de fuga las contraseñas vigentes
El generador de capturas seguía usando la marca antigua y un panel que la demo pública no tiene	Nadie lo había corrido desde el cambio de nombre	Se corrigió el generador y se verificó cada imagen a ojo antes de aceptarla
El repositorio de evaluación no mostraba el trabajo real	El código vivía en otro repositorio	El repositorio de evaluación recibe el historial completo de desarrollo y la documentación que pide el instructivo

Regla que queda: antes de publicar algo nuevo se buscan claves y datos de personas reales, también en el historial, y se revisan a mano las imágenes.

Acciones de mejora incorporadas

Acción	Dónde quedó
Permisos explícitos por tabla para <code>authenticated</code> y <code>service_role</code>	Migración 0016 y convención de tablas
Correr <code>db lint</code> y <code>test:db</code> después de aplicar cada migración	Definition of Done (REV-05), sección de base de datos
Bloquear en los guards y en la base al lead con solicitud pendiente	<code>src/lib/tenantGuards.ts</code> y base de datos; invariante 9
Reglas por perfil dentro de la base	Migración 0022; <code>test:db</code> en 0 fallas
Sesión obligatoria para el asistente publicado y política de contenido (CSP)	<code>server/session.ts</code> ; configuración de publicación
Cambios de presupuesto y de clave registrados por funciones de la base	Migraciones 0031 y 0032
Cada empresa con su propia clave de OpenAI, cifrada	Migración 0032 (Vault)

Acción	Dónde quedó
Pruebas de mutación a mano para las pruebas de seguridad	test:ai
Escanear claves y datos reales antes de publicar, también en el historial	Checklist «Antes de publicar» (REV-05)

Iteración 5: retrospectiva de cierre (a completar el 06-10-2026)

¿Qué salió bien?	¿Qué no salió bien?	¿Qué cambiaremos?